Folio

Invoicing for freelancers, rebuilt so the books can be trusted.

A clean-room rebuild of Accountill. Express + SQLite + React.

Fixes all 15 defects found in the reverse-engineering report.

The problem with the original

Anyone can read or change anyone's invoices

No route checks the caller. The auth middleware exists but is never used (server/index.js:30-35).

The owner is whatever the browser says

The user id arrives as a query parameter. Update and delete check no owner (invoices.js:10,13,85-98).

GET /clients returns every user's clients

No filter at all (clients.js:44-45).

Totals, status and payments are trusted from the browser

The server saves the request body as the invoice (invoices.js:53-57).

Invoice numbers are count + 1 in the browser

No uniqueness rule in the schema (Invoice.js:96, InvoiceModel.js:13).

Our two improvements

1. Real authentication and per-user ownership on every route

Every data route needs a verified token. The owner is only the token's user. Another user's record is a 404. No password hash is ever returned.

2. Server-assigned unique invoice numbers, server-computed totals

An atomic per-user counter plus UNIQUE(user_id, number). Totals and status are derived on the server and never taken from the client.

The other defects (PDF, email relay, timestamps, reset flow, Docker, tests) are fixed too. See docs/GAPS.md.

What we built

Clients, invoices, payments, dashboard

Create and edit invoices, record and remove payments, see received, outstanding and overdue totals.

PDF and email

PDF rendered in memory per request. Email goes only to the client's saved address, rate limited.

Money done safely

Integer cents, derived status, a payments endpoint that rejects zero and overpayment, atomic under concurrency.

Calm, mobile-first interface

No horizontal scroll at 320 to 1280 px. Every failed request shows a message and stops loading.

How we know it works

15 API tests, each named for the defect it proves

Unauthenticated and tampered tokens get 401. Cross-user access gets 404. 20 parallel creates give 20 distinct numbers. Five simultaneous payments record exactly the amount the balance allows.

Walked through in a real browser

Sign-up, client, invoice, payments, PDF, edit rejected below paid amount, delete, sign-out and route guard.

Not verified: Docker image build, real SMTP delivery, Google sign-in with a live client id. See docs/AGENT_LOG.md.

Run it

```
npm install
npm run build
npm start          # http://localhost:4000
npm test
```

Node 22 or later. No database server needed. Configuration is optional; see .env.example.